STERICORD | QUALITY ASSURANCE

STERICORD

Targeted Remediation QA Retest Report

Verification of defects D-01 through D-07 covering audit controls, quarantine atomicity, incident lifecycle logging, offline mobile behavior, reporting authorization and account deactivation.

NO-GO

Report version	2.0
Execution date	6 September 2026
Tester	Codex automated/local retest
Environment	Local macOS / Supabase / Postgres / Docker / Flutter SDK
Source report	SteriCord Full-Flow QA Test Report, Version 1.0
Retest scope	Previously flagged defects and directly affected regression controls

> **Scope note.** This was a targeted remediation retest, not a fresh execution of all 22 original full-flow cases. Physical-device, real Document AI, real Gemini and other unavailable checks are not represented as passed.

1. Executive Summary

The targeted retest executed the new database, authorization, reporting and build validations against the updated local codebase. Audit coverage, quarantine consistency, incident lifecycle events, report role restrictions and malformed bearer handling now pass their automated acceptance checks. The core FF-20 data-access defect is also corrected: a JWT issued before deactivation returns no protected equipment rows immediately after the profile is disabled.

5	1	1	32
REMEDIATIONS PASSED	FAILED / INCOMPLETE	BLOCKED	SCRIPT CHECKS PASSED

Release-critical conclusions

- **D-01, D-02 and D-03 passed:** equipment auditing, quarantine record atomicity and incident lifecycle event naming behaved as required.
- **D-05 and D-06 passed:** unauthorized report roles are denied before data access/export logging, and malformed credentials return 401 rather than 500.
- **D-07 is only partially resolved:** existing-token protected reads are blocked and no fresh token is issued, but a deactivated user's password-login request returns HTTP 500 instead of a controlled 401/403 response.
- **D-04 remains blocked:** the mobile implementation compiles and contains the expected encrypted queue/idempotency mechanisms, but the required connectivity-loss and recovery scenario was not executed on a physical iPhone or Android device.
- **FF-22 remains incomplete:** Android, low-storage, printed-QR, reproducible glare and mobile MFA/TOTP coverage remain outstanding.

> **Release recommendation: NO-GO.** Do not change the pilot-release gate until D-04/FF-16 passes on physical devices, the deactivated-login 500 is corrected and retested, and the remaining P0/P1 validation gaps receive execution or formal risk acceptance.

Automated execution totals

Suite	Result	Evidence
Database/security remediation suite	**17 PASS / 0 FAIL**	Tenant isolation, audit immutability, D-01, D-02, D-03 and D-07 RLS enforcement.
Reporting authorization suite	**15 PASS / 0 FAIL**	D-05/D-06 roles, all report routes, export auditing, valid PDF, malformed tokens and cross-tenant 404.
Web quality gates	**PASS**	ESLint, TypeScript no-emit check and Vite production build.
Flutter tests	**2 PASS**	Existing model round-trip tests only; no automated offline workflow coverage.
Flutter analysis	**1 INFO**	Deprecated `anonKey` use in lib/main.dart; no compile error reported.

2. Test Environment and Method

Component	Execution value
Repository	/Users/nabilfn/SteriCord working tree containing the remediation changes
Supabase API/Auth	http://127.0.0.1:54421
Postgres	127.0.0.1:54422 / database postgres
Reporting service	Fresh Docker build, http://localhost:8000
Flutter	Installed local SDK; static analysis and unit tests executed
Physical mobile devices	Unavailable during this retest
OCR / Gemini	Real external-service credentials not exercised

Method

Each defect was assessed using executable regression checks where available, then cross-checked against the implementation and fresh database/API evidence. Negative authorization checks were considered successful only when the action was denied and downstream audit state remained clean. A source-code implementation was not treated as proof of physical-device behavior.

Applied remediation migrations

The local migration ledger confirms all seven 6 September migrations were applied, from `20260906000001_enforce_active_profile` through `20260906000007_report_export_authorization`.

Outcome definitions

Outcome	Meaning in this report
PASS	The remediated behavior was directly exercised and met the targeted acceptance criteria.
FAIL	At least one required behavior produced an incorrect or incomplete result.
BLOCKED	The required execution environment or device was unavailable; code inspection alone is insufficient.

> **Safety statement.** AI remains advisory. This retest did not change or re-evaluate the requirement that only authorized humans make authoritative PASS/FAIL decisions and release packs.

3. Targeted Retest Results

ID	Result	Execution conclusion	Primary evidence
D-01 FF-04	**PASS**	Create, status change and metadata edit emitted the required distinct audit events.	Entity 9451ec5f-d92a-4f1f-891a-256e8a490ad5; EQUIPMENT_CREATED, EQUIPMENT_STATUS_CHANGED, EQUIPMENT_UPDATED.
D-02 FF-06	**PASS**	quarantine_pack() created one quarantine row; repetition was rejected without duplication.	Pack 40b10910-5c40-4057-9044-f648ccf55b55; PACK_QUARANTINED and QUARANTINE_STARTED.
D-03 FF-14	**PASS**	Full tested lifecycle emitted exactly four correctly named events; invalid transitions were rejected.	Incident d56c3a9b-630c-43d9-b083-d7339fd4c340.
D-04 FF-16	**BLOCKED**	Implementation evidence exists, but physical connectivity-loss, restart and interrupted-sync behavior was not executed.	Flutter tests 2/2 pass; no offline-flow tests; no physical iPhone/Android evidence.
D-05 FF-19	**PASS**	OT_NURSE and CSSD_TECHNICIAN exports were denied; authorized roles produced PDFs; cross-tenant policy remained safe.	15/15 reporting checks; no blocked-attempt REPORT_EXPORTED rows.
D-06 FF-19	**PASS**	Empty, whitespace, missing and malformed credentials returned HTTP 401.	No tested malformed credential returned HTTP 500.
D-07 FF-20	**FAIL**	Core data denial passed, but a new login by a deactivated account returned HTTP 500 instead of controlled 401/403.	Existing JWT: 200 with []; new password login: 500; no new token issued.

Regression integrity

Hospital B could not read Hospital A equipment/audit data or verify Hospital A's audit chain. Client audit deletion remained blocked. The final audit-chain verification returned zero issues. The latest observed event was `ab44074a-6074-463e-b684-6d095dea3f93`. hash `df42857b3bad9f51cd13e595bd350934704848d0c2d4aa1b43102b2f1afb261d`.

4. Detailed Evidence and Observations

4.1 D-01 — Equipment audit coverage

A synthetic equipment record was created, moved to MAINTENANCE and edited. Audit inspection returned exactly EQUIPMENT_CREATED, EQUIPMENT_STATUS_CHANGED and EQUIPMENT_UPDATED in order. The equipment trigger performs server-side logging, and audit-chain verification remained intact.

4.2 D-02 — Quarantine atomicity

A synthetic pack was moved to PENDING_VERIFICATION and quarantined as a supervisor. Exactly one public.quarantines row was created. A second quarantine attempt was rejected and the row count remained one. Both PACK_QUARANTINED and QUARANTINE_STARTED events referenced the same pack.

4.3 D-03 — Incident lifecycle auditing

The incident advanced ALERTED → ACKNOWLEDGED → REPLACEMENT_DISPATCHED → RESOLVED → CLOSED. The resulting sequence was INCIDENT_ACKNOWLEDGED, INCIDENT_REPLACEMENT_DISPATCHED, INCIDENT_RESOLVED and INCIDENT_CLOSED. Empty resolution notes, nurse acknowledgement and terminal regression were rejected.

4.4 D-04 — Offline OT queue

Static inspection found encrypted payload storage, a secure-storage encryption key, persistent queue states, stable client operation IDs, server-side idempotency, recovery of SYNCING records and capped exponential delay. Authentication changes also preserve a cached authenticated profile during transport failures.

This does not prove physical-device acceptance. The original scenario must still be repeated with radios disabled while an eligible pack is open.

4.5 D-05/D-06 — Reporting

The freshly rebuilt reporting service denied OT_NURSE and CSSD_TECHNICIAN report exports with 403, allowed HOSPITAL_ADMIN and CSSD_SUPERVISOR equipment exports, produced a valid PDF, denied Hospital B access to Hospital A equipment with 404, and created no success export row for blocked nurse attempts. Empty, whitespace-only, missing and garbage bearer credentials all returned 401.

4.6 D-07 — Deactivation

An active technician JWT initially read protected equipment successfully. After profiles.is_active was set false, the same JWT received HTTP 200 with an empty array, proving immediate authoritative RLS denial. A new password-login attempt did not issue a token but returned HTTP 500. The seeded technician profile was restored to active after the test.

5. Build and Static Validation

Check	Result	Observation
Web ESLint	**PASS**	No lint errors.
Web TypeScript	**PASS**	`tsc -b --noEmit` completed successfully.
Web production build	**PASS**	1,733 modules transformed; build completed. Vite reported a non-blocking bundle-size warning for a 571.38 kB JavaScript chunk.
Flutter unit tests	**PASS**	2/2 existing tests passed: UserRole and EquipmentStatus database-value round trips.
Flutter analyzer	**ATTENTION**	One informational deprecation: anonKey in lib/main.dart should migrate to publishableKey. No offline-specific analyzer error was reported.
Reporting Python compile	**PASS**	Application sources compiled successfully using an isolated bytecode cache.
Reporting Python unit tests	**NOT AVAILABLE**	No pytest dependency/test suite was available in the service environment. API behavior was validated through the Dockerized integration script.

Important coverage limitation

> The mobile test suite has no automated coverage for queue encryption, process restart, killed-app SYNCING recovery, retry classification, duplicate suppression or UI state transitions. These behaviors were supported by source inspection only and remain subject to physical-device execution.

Commands executed

```
./infrastructure/deployment/security-checks.sh
./infrastructure/deployment/report-authorization-checks.sh
npm run lint && npm run typecheck && npm run build
flutter analyze
flutter test
python3 -m compileall -q app
```

6. Defect Register and Validation Gaps

ID	Severity	Title	Evidence / required action
D-08	S2 / Medium	Deactivated login returns HTTP 500	The custom access-token hook prevents token issuance but surfaces the rejection as an internal-server response. Return a controlled 401/403 with a stable, non-sensitive message; retest password login and refresh.
G-01	P0 validation	Physical offline POU retest absent	Repeat FF-16 steps 64–67 on physical iPhone and Android, including queue-at-rest inspection, restart, interrupted SYNCING, retry and duplicate checks.
G-02	P0 validation	Mobile acceptance incomplete	Android, low-storage, printed QR, reproducible glare and mobile MFA/TOTP remain unexecuted or unimplemented.
G-03	P1 validation	Real OCR path unavailable	Configure controlled Google Document AI credentials and execute real OCR prefill/confidence cases.
G-04	P1 validation	Real Gemini path unavailable	Configure Gemini and execute representative PASS, FAIL and ambiguous advisory cases.
G-05	Cross-cutting	Formal readiness evidence absent	Run production monitoring/alert drill and capture CSSD, OT, security/privacy and product-owner approval.

Retest plan

1. Correct the custom access-token-hook error mapping and prove deactivated login and refresh return a controlled 401/403 with no token.
2. Add automated mobile tests for encrypted persistence, restart recovery, retry/conflict classification and idempotent replay.
3. Repeat the complete FF-16 physical-device sequence on iPhone and Android.
4. Complete the remaining FF-22 device and MFA coverage.
5. Execute or formally disposition the real-service OCR/Gemini cases.

7. Release Gate Assessment

Gate	Decision	Evidence / rationale
Audit remediation	PASS	D-01 and D-03 passed; audit-chain verification returned zero issues.
Quarantine consistency	PASS	D-02 passed for creation and repeat rejection.
Report security	PASS	D-05/D-06 passed 15 integration checks.
User deactivation	PARTIAL	Existing-token access is blocked, but login rejection returns 500.
Mobile offline acceptance	NO	Required physical-device execution remains outstanding.
Mobile/device acceptance	NO	FF-22 gaps remain, including Android and mobile MFA.
External AI/OCR validation	PENDING	Real controlled credentials were not available for this retest.
Clinical/security/product sign-off	PENDING	No formal approval evidence was captured.
Final release decision	NO-GO	Do not proceed to pilot until the physical offline/device gates pass and remaining auth/validation findings are resolved or formally accepted.

8. Final Recommendation

NO-GO FOR PILOT RELEASE

The remediation materially improves SteriCord's audit completeness, workflow consistency, reporting authorization and immediate deactivation enforcement. The release decision nevertheless remains NO-GO because the offline OT scenario—the original physical iPhone release blocker—has not been rerun on devices, FF-22 acceptance remains incomplete, and deactivated login currently presents an internal-server response.

Approval Sign-off

Role	Name	Signature / date
QA lead		
CSSD clinical lead		
OT clinical lead		
Security / privacy		
Product owner		